

Veille technologique & sécurité

Démarche de veille mise en place autour de **Petit Rayon de Soleil** : suivre les évolutions des technologies utilisées et anticiper les problématiques de sécurité liées au déploiement.

Projet Petit Rayon de Soleil **Auteur** de Breyne Hélió **Périmètre** Node.js · Vercel · npm · sécurité web

1 Veille technologique

Chaque brique du projet fait l'objet d'un suivi, avec une source de référence et un rythme adapté à sa criticité. L'objectif : ne pas subir une rupture (version dépréciée, faille) mais l'anticiper.

Axe	Ce que je surveille	Source suivie	Rythme
Vercel	Nouveautés de la plateforme, évolutions du runtime serverless, limites du plan gratuit.	vercel.com/changelog Blog Vercel	mensuel
Node.js	Cycle de vie des versions (LTS), fonctionnalités natives (node:test , node:sqlite), dépréciations.	nodejs.org/blog Calendrier des releases	mensuel
Dépendances npm	Nouvelles versions et failles de express , bcryptjs , @libsql/client .	npm audit GitHub Dependabot	à chaque install
Base de données	Évolutions de Turso / libSQL, compatibilité avec SQLite.	docs.turso.tech Changelog Turso	trimestriel

Outils de veille passive. Deux automatismes réduisent l'effort manuel : **GitHub Dependabot** ouvre automatiquement une pull request quand une dépendance a une mise à jour de sécurité, et **npm audit** (intégrable au pipeline CI) signale les vulnérabilités connues à chaque installation.

2 Veille sécurité & bonnes pratiques

La sécurité du déploiement s'appuie sur un référentiel reconnu (OWASP) et sur des pratiques déjà appliquées dans le code. Chaque carte indique la pratique et son état actuel dans le projet.

SECRETS

Sécurité des secrets

Les identifiants sensibles (jeton Turso, URL de base) ne doivent jamais se retrouver dans le dépôt. Ils sont fournis uniquement par **variables d'environnement**, et le fichier `.env` est exclu du versionnement.

État projet : appliqué — `.env` et `.vercel` listés dans `.gitignore` ; aucun secret en dur dans le code (vérifié).
Veille : rotation des jetons et bonnes pratiques de gestion des secrets Vercel.

OWASP

Bonnes pratiques OWASP

Le **Top 10 OWASP** sert de grille de lecture des risques web courants (injection, mauvaise authentification, contrôle d'accès défaillant...). C'est la référence suivie pour la sécurité applicative.

État projet : plusieurs risques déjà couverts — **injection SQL** neutralisée par requêtes paramétrées ; **mots de passe** hachés (bcrypt) ; **contrôle d'accès** via middlewares `requireAuth` / `requireAdmin`. Veille : évolutions du Top 10 et nouvelles recommandations.

PACKAGES

Mises à jour des packages

Une dépendance obsolète est une porte d'entrée potentielle. La politique est double : **peu de dépendances** (surface réduite) et **mise à jour régulière** des versions, priorisée sur les correctifs de sécurité.

État projet : 3 dépendances runtime seulement. Contrôle par `npm audit` — **0 vulnérabilité** à ce jour. Veille : suivi des correctifs via Dependabot.

Contrôle de sécurité des dépendances

La commande ci-dessous, exécutable à tout moment et intégrable au pipeline CI, dresse l'état des vulnérabilités connues :

```
bash — npm audit
```

```
$ npm audit
found 0 vulnerabilities
```

3 De la veille à l'action

La veille n'a de valeur que si elle déclenche une réaction. Le circuit est le suivant :

- **Alerte reçue** (Dependabot, npm audit , changelog) → évaluation de la criticité.
- **Correctif de sécurité** → mise à jour de la dépendance, puis npm test (15 tests) pour vérifier l'absence de régression.
- **Validation par la CI** → le pipeline GitHub Actions rejoue installation, qualité et tests avant toute fusion.
- **Déploiement** → une fois au vert, Vercel remet en ligne automatiquement.

En résumé. La veille (Dependabot, npm audit, changelogs Node/Vercel/Turso) alimente un cycle court : détecter → corriger → tester → déployer. Les dépendances minimales et les pratiques OWASP déjà en place rendent ce cycle rapide et peu risqué.

Petit Rayon de Soleil — Annexe « Veille technologique & sécurité ». État sécurité (0 vulnérabilité, secrets hors dépôt, requêtes paramétrées) vérifié sur le projet.